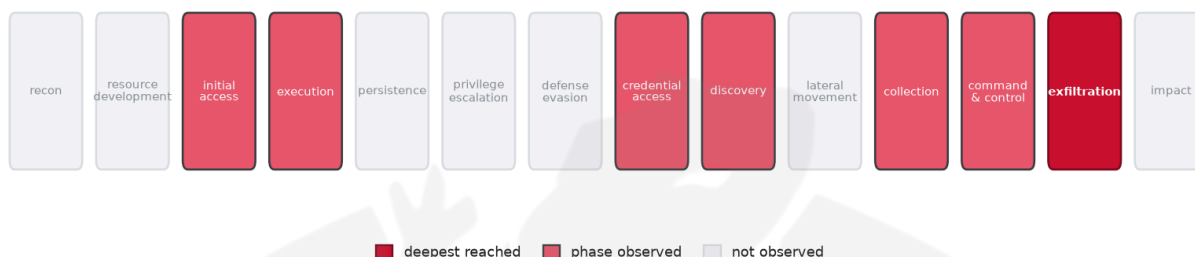


THREAT REPORT: CONTAGIOUS INTERVIEW

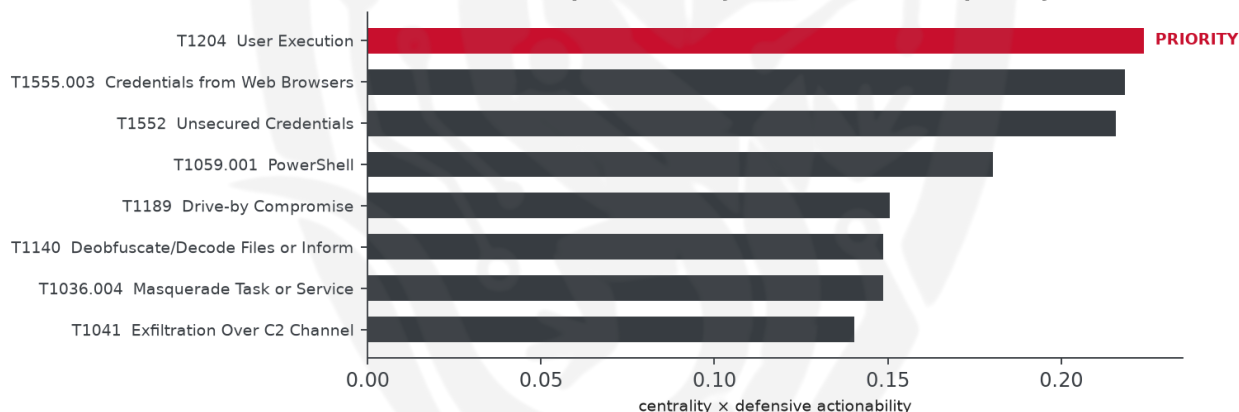
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: exfiltration)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The threat actor, attributed by the source to Contagious Interview, has been observed utilizing malware families OTTERCOOKIE and BEAVERTAIL to target the technology sector. The priority defensive action should be to block execution of downloaded HTA/JS/LNK files and enforce mark-of-the-web, among other controls. The actor's campaign involves exploiting various techniques to gain access to sensitive information. Priority should be given to preventing user execution of malicious files to mitigate the risk of exfiltration.

Threat Overview

The observed cluster of activity, attributed to Contagious Interview by the source, involves the use of OTTERCOOKIE and BEAVERTAIL malware families. The central vulnerability exploited is currently unknown, but the actor has been observed using multiple techniques, including screen capture, JavaScript, and system information discovery, to target technology sector entities.

Attack Chain and Priority Control

The attack chain involves a series of techniques, including user execution, system information discovery, and data exfiltration over a command and control channel. The priority technique is T1204 User Execution, which serves as a chokepoint in the attack chain. To mitigate this threat, the priority control is to "Block execution of downloaded HTA/JS/LNK; enforce mark-of-the-web; disable Office macros from the internet; user awareness on lures."

Infrastructure and Corroboration

There is no observed hosting provider or ASN associated with this campaign, and no malware families have been corroborated by abuse.ch. Additionally, no indicators have been flagged with high confidence by AbuseIPDB, with the highest confidence seen being 0%.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1113 Screen Capture
- T1059.007 JavaScript
- T1071.004 DNS
- T1497.001 System Checks
- T1115 Clipboard Data
- T1082 System Information Discovery
- T1005 Data from Local System
- T1140 Deobfuscate/Decode Files or Information
- T1552 Unsecured Credentials
- T1555.003 Credentials from Web Browsers
- T1083 File and Directory Discovery
- T1036.004 Masquerade Task or Service
- T1204 User Execution
- T1041 Exfiltration Over C2 Channel
- T1059.001 PowerShell
- T1027.003 Steganography
- T1189 Drive-by Compromise
- T1071.001 Web Protocols
- T1105 Ingress Tool Transfer

Analytical Scores

- Priority technique (graph chokepoint): T1204 User Execution (centrality 0.2797).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.5; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Winter Vivern	0.5
Stealth Falcon	0.4129
Dark Caracal	0.4129
APT37	0.4111
Windigo	0.378

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Domain	controller[.]rightwidth[.]dev
Domain	file[.]rightwidth[.]dev
Domain	ldb[.]rightwidth[.]dev
Domain	upload[.]rightwidth[.]dev
Hash	3e6360f83a95540aa2176d279ca4694513afb1e5116a7ffe591c6b5bcf3b9c3c
Hash	4e7639045b4a64de60bfb6312951a5c3dffbd3fb04b84837663242ed27f09864
Hash	54bf36910d81ab516037cb3d69d7c85190f90aa0da9e58617799c1fc738dc5a9
Hash	8e571d58794b9b44ae53c2c67bedef72c500e8adbb80aab7a5c263adcba55b1e
Hash	96357529d17c4690826d5d4c74deac51743a5388733b3f04004d898f0635ef20

Type	Indicator
Hash	9df01d242ef46adfedf8c35cb7cc67b1d27d7dc4a1ce74ab32e984090d579886
Hash	c5aed4c063d4970a03250778da8041da9e0c83d8f22d2f1994da0ad72567ebd9
Hash	cc97517f80f567977300450de11e9a0be53f52657525a20b1091c99fe9e45730
Hash	fb94b2caee2c40635448a98ba0118421e19a400e74ccff73315f8fa42351f53f

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1204 User Execution (execution)
- **Observed here:** Contagious Interview used T1059.001 PowerShell here as an alternative execution technique.
- **Projected pivot:** T1059.001 PowerShell (execution)
- **Basis:** observed in this campaign (an alternative the actor already demonstrated).

The Contagious Interview actor could pivot to using T1059.001 PowerShell to maintain their objective by leveraging PowerShell's versatility in executing commands and scripts, potentially allowing them to bypass the blocked User Execution technique. They may attempt to utilize PowerShell to execute malicious code or scripts, which would likely be a key aspect of their campaign. To counter this, the defensive control of Constrain PowerShell (Constrained Language Mode + AppLocker/WDAC); enable script-block and module logging; alert on encoded commands should be implemented.

Detection and hardening for the pivot (T1059.001 Command and Scripting Interpreter)

- **Telemetry:** Sysmon / EDR process + command line; PowerShell Script Block Logging (4104); AMSI
- **Detect:**
 - Security 4688 / Sysmon 1 with full command lines; encoded or obfuscated PowerShell
 - PowerShell 4104 script-block content; suspicious cmdlets and download cradles
 - Office or browser processes spawning powershell/cmd/wscript
- **Harden:**
 - Enable Script Block Logging + AMSI; Constrained Language Mode
 - Application control (WDAC/AppLocker); remove/limit unused interpreters
- **MITRE:** M1049 Antivirus/Antimalware, M1038 Execution Prevention, M1042 Disable or Remove Feature, M1045 Code Signing · DS0009 Process, DS0012 Script, DS0017 Command